

Организация

**ПОЛИТИКА ИНФОРМАЦИОННОЙ
БЕЗОПАСНОСТИ**

**Политика информационной
безопасности**

Объект защиты: Информационная система персональных данных

Категория: Персональные данные

СОГЛАСОВАНО:

Руководитель службы ИБ

«_____» _____ 20____ г.

г. Омск, 2026

Содержание

1	Общие положения	3
1.1	Область применения и цели Политики	3
1.2	Термины и определения	3
1.3	Требования к защите персональных данных	4
1.3.1	Организационные меры	4
1.3.2	Технические меры и защита каналов связи	4
1.3.3	Шифрование и хранение данных	4
1.3.4	Управление инцидентами и журналирование	5
1.3.5	# Управление доступом и идентификацией	5
1.3.6	# Шифрование данных и каналов связи	6
1.3.7	# Журналирование и мониторинг событий	6
1.3.8	# Управление инцидентами и реагирование	7
1.4	Персональные данные (ПДн)	7
1.5	Информационная безопасность (ИБ)	8
1.6	Уровень защищенности (УЗ)	8
1.7	Критическая информация и системы (КИИ)	9
1.8	Шифрование данных	9
1.9	Журналирование событий	10
1.10	Управление доступом и аутентификация	10
1.11	Шифрование и защита данных	11
1.12	Сетевая безопасность и сегментация	11
1.13	Журналирование событий и мониторинг	12
1.14	Организационные и физические меры	12
1.15	Аутентификация пользователей	13
1.16	Авторизация и принцип минимальных привилегий	13
1.17	Технические меры контроля доступа	14
1.18	Журналирование и управление учетными записями	14
1.19	Персонал и доступ к информации	15

1.20	Обращение с персональными данными	15
1.21	Технические и операционные меры защиты	16
1.22	Реагирование на инциденты	17
1.23	Техническое журналирование событий	17
1.24	Мониторинг и обнаружение инцидентов	18
1.25	Периодический аудит и тестирование	18
1.26	Отчетность и документация	19
1.27	Область применения и ответственность	19
1.28	Регламент пересмотра и актуализации	20
1.29	Технические и организационные меры	20
1.30	Управление инцидентами	21
1.31	Контроль исполнения	21
Нормативные ссылки		23

1. Общие положения

1.1. Область применения и цели Политики

Настоящая Политика определяет требования к обеспечению безопасности персональных данных (ПДн) и информационных систем, используемых в БУЗОО «МИАЦ» (далее — Организация). Политика обязательна для исполнения всеми сотрудниками, подрядчиками и информационными системами, обрабатывающими ПДн в соответствии с законодательством Российской Федерации.

В соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных» и Приказом ФСТЭК России № 21, Организация обязуется обеспечить защиту конфиденциальной информации на всех этапах ее жизненного цикла. Целью документа является минимизация рисков несанкционированного доступа, изменения, уничтожения или блокирования ПДн, что является критически важным для сохранения медицинской тайны и соблюдения прав субъектов ПДн.

1.2. Термины и определения

Политика определяет ряд ключевых терминов, используемых в документе. Под персональными данными понимается любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу. Информационная безопасность (ИБ) — это состояние защищенности информации, обеспечивающее ее конфиденциальность, целостность и доступность.

С учетом требований Приказа Минздрава № 956н, медицинская тайна рассматривается как особый вид ПДн, требующий повышенного уровня защиты. Должно быть обеспечено строгое разграничение доступа к данным, что является обязательным условием функционирования медицинской информационной системы.

1.3. Требования к защите персональных данных

1.3.1. Организационные меры

Обязательным является разработка и внедрение организационных мер, направленных на предотвращение утечек и несанкционированного использования ПДн. Необходимо внедрить систему управления доступом, которая предусматривает принцип минимально необходимых привилегий.

Требуется организовать регулярное обучение персонала, в ходе которого проводится инструктаж по обработке ПДн и особенностям соблюдения режима конфиденциальности. В частности, должно быть обеспечено ознакомление всех сотрудников с последними изменениями в законодательстве, регулирующем сферу обработки ПДн.

1.3.2. Технические меры и защита каналов связи

Система защиты информации включает комплекс технических средств, предназначенных для обеспечения целостности и конфиденциальности передаваемых данных. Обязуется обеспечить использование защищенных каналов связи при передаче ПДн между филиалами или внешними контрагентами.

В соответствии с требованиями ФСТЭК России, необходимо внедрить механизмы шифрования данных как при передаче (TLS/VPN), так и при хранении. Подлежит выполнению регулярная проверка работоспособности средств защиты информации, включая межсетевые экраны и системы обнаружения вторжений.

1.3.3. Шифрование и хранение данных

Для защиты ПДн, содержащих сведения о здоровье, требуется использование криптографических средств защиты информации. Должно быть обеспечено шифрование персональных данных, хранящихся в базах данных, с использованием алгоритмов, соответствующих требованиям законодательства.

Производится проверка соответствия используемых криптографических средств

требованиям ГОСТ. При этом, в случае обработки медицинских данных, особое внимание уделяется защите от несанкционированного доступа к резервным копиям, которые должны храниться в защищенном контуре.

1.3.4. Управление инцидентами и журналирование

Осуществляется мониторинг всех критически важных информационных систем для выявления аномалий и попыток несанкционированного доступа. Является обязательным ведение подробного журнала событий (журналирование), фиксирующего все действия пользователей с ПДн.

Необходимо внедрить процедуру реагирования на инциденты информационной безопасности. При обнаружении инцидента должно быть немедленно инициировано локализованное реагирование, с последующим составлением акта об инциденте и уведомлением ответственных лиц в соответствии с внутренними регламентами.

Данный комплекс мер обеспечивает выполнение требований, установленных в законодательстве, в частности, в части защиты информации, составляющей медицинскую тайну, и соответствует требованиям [152-ФЗ, ст. 19] и [ФСТЭК №21, п. 15]. ## Нормативные ссылки

1.3.5. # Управление доступом и идентификацией

Должно быть обеспечено строгое разграничение доступа к информационным ресурсам, что является обязательным требованием в соответствии с требованиями законодательства Российской Федерации. Необходимо внедрить систему аутентификации, предусматривающую использование не менее двух факторов (двухфакторная аутентификация) при входе в сегменты, содержащие персональные данные пациентов. Политика определяет, что права доступа должны быть назначены на основе принципа минимально необходимых привилегий, исключая избыточные полномочия у конечных пользователей.

Требуется организовать процесс периодического пересмотра прав доступа,

который должен проводиться не реже одного раза в квартал. Обязуется обеспечить ведение детализированного учета всех субъектов, имеющих доступ к медицинским информационным системам (МИС). В частности, при увольнении или переводе сотрудника должен быть инициирован незамедлительный процесс аннулирования всех учетных записей и предоставления соответствующих учетных данных. Это соответствует положениям [152-ФЗ, ст. 19] и минимизирует риски несанкционированного доступа.

1.3.6. # Шифрование данных и каналов связи

Является обязательным применение криптографических средств защиты информации при передаче персональных данных пациентов. Необходимо внедрить механизмы шифрования как при передаче данных по незащищенным каналам связи, так и при их хранении в информационных базах. В соответствии с требованиями [ФСТЭК №21, п. 15], при передаче данных между филиалами или внешними контрагентами должен использоваться защищенный VPN-канал с применением протоколов, обеспечивающих высокий уровень криптографической стойкости, например, TLS 1.2 или выше.

Обязуется обеспечить шифрование персональных данных в состоянии покоя (at rest). Это означает, что все базы данных, содержащие ПДн, должны быть защищены средствами шифрования на уровне диска или приложения. При работе с данными, полученными в рамках оказания медицинской помощи, должно быть обеспечено применение методов псевдонимизации и деперсонализации, что является ключевым требованием для соблюдения конфиденциальности.

1.3.7. # Журналирование и мониторинг событий

Осуществляется непрерывный мониторинг всех критически важных информационных систем, включая системы регистрации и обработки ПДн. Производится сбор и централизованное хранение журналов событий (логирования) всех действий пользователей, администраторов и автоматизированных процессов. Дан-

ные журналы должны содержать информацию о времени, субъекте, типе действия и объекте воздействия.

Политика определяет, что система SIEM (Security Information and Event Management) должна быть настроена для автоматического анализа журналов в режиме реального времени. Выполняется анализ аномальных событий, таких как попытки массового экспорта данных или вход в систему с необычного географического местоположения. Подлежит выполнению регулярная проверка целостности журналов, гарантирующая невозможность их несанкционированного изменения или удаления.

1.3.8. # Управление инцидентами и реагирование

Требуется разработка и актуализация Плана реагирования на инциденты информационной безопасности. Обязуется обеспечить формирование четкой иерархии ответственных лиц, которые будут координировать действия в случае обнаружения нарушения режима защиты. В случае инцидента, связанного с утечкой ПДн, должно быть инициировано немедленное оповещение ответственных структур и, при необходимости, надзорных органов.

Система предусматривает проведение регулярных учений и тренировок по отработке действий персонала в условиях кризисной ситуации. Необходимо проводить анализ уязвимостей информационных систем не реже одного раза в год, с учетом рекомендаций, изложенных в [Минздрав №956н]. Все выявленные уязвимости должны быть классифицированы по степени критичности и устранению подлежит выполнение в установленные сроки, что гарантирует устойчивость функционирования МИС. # Термины и определения

1.4. Персональные данные (ПДн)

Персональные данные определяются как любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому ли-

цу. В соответствии с требованиями [152-ФЗ, ст. 19], обработка ПДн должна осуществляться исключительно с согласия субъекта данных, за исключением случаев, предусмотренных законодательством Российской Федерации. Организация обеспечивает защиту ПДн путем внедрения комплексных мер, направленных на предотвращение несанкционированного доступа, уничтожения или изменения информации. Необходимо строго соблюдать принцип минимизации данных, что означает, что при обработке должна использоваться только та информация, которая является абсолютно необходимой для достижения конкретной законной цели.

1.5. Информационная безопасность (ИБ)

Информационная безопасность представляет собой состояние защищенности информационных ресурсов, обеспечивающее их непрерывную и бесперебойную работу. Политика определяет ИБ как совокупность организационных, технических и правовых мер, направленных на защиту конфиденциальности, целостности и доступности обрабатываемой информации. Должно быть обеспечено поддержание трех ключевых свойств информации: конфиденциальность, гарантирующая, что данные доступны только авторизованным субъектам; целостность, требующая отсутствия несанкционированных изменений; и доступность, обеспечивающая своевременный доступ к информации уполномоченным сотрудникам. Осуществляется мониторинг всех процессов, связанных с обработкой ПДн, с целью выявления потенциальных угроз и своевременного реагирования на инциденты.

1.6. Уровень защищенности (УЗ)

Уровень защищенности — это совокупность требований к защите информации, определяемая в соответствии с классификацией угроз и значимости обрабатываемых данных. Внедрение мер защиты должно производиться с учетом требований, изложенных в нормативных документах, например, в соответствии с

требованиями ФСТЭК России. Является обязательным проведение анализа защищенности информационных систем, который позволяет определить минимально необходимый УЗ. Требуется организовать систему классификации информации, которая должна учитывать не только тип данных, но и степень их критичности для деятельности БУЗОО «МИАЦ». Например, медицинская тайна, являясь особо чувствительной категорией ПДн, требует присвоения максимального уровня защищенности.

1.7. Критическая информация и системы (КИИ)

Критическая информация и системы — это сведения и технические средства, отказ или компрометация которых может повлечь за собой серьезный ущерб функционированию медицинской организации и угрозу жизни пациентов. Необходимо разработать и внедрить перечень КИИ, который должен быть актуализирован ежеквартально. Производится проверка всех информационных систем, обрабатывающих КИИ, с целью подтверждения их устойчивости к внешним и внутренним воздействиям. Обязуется обеспечить резервирование данных КИИ и разработать четкие процедуры восстановления работоспособности систем в случае аварийных ситуаций.

1.8. Шифрование данных

Шифрование данных — это процесс преобразования исходной информации (открытого текста) в нечитаемый формат (шифротекст) с использованием криптографических алгоритмов. Требуется применение надежных и сертифицированных средств криптографической защиты информации (СКЗИ) при передаче ПДн по незащищенным каналам связи, например, через VPN-туннели. В частности, при хранении данных в информационных системах должно быть обеспечено шифрование на уровне базы данных, используя алгоритмы, соответствующие современным стандартам, таким как AES. Запрещается передавать ПДн в незашиф-

рованном виде, даже если канал связи считается внутренним.

1.9. Журналирование событий

Журналирование событий — это процесс автоматической фиксации всех значимых действий, происходящих в информационных системах. Осуществляется сбор и централизованное хранение журналов событий (логов) из всех ключевых компонентов ИС, включая рабочие станции, серверы и сетевое оборудование. Является обязательным регулярный анализ этих журналов с помощью специализированных систем SIEM, что позволяет выявлять аномалии и попытки несанкционированного доступа. Подлежит выполнению процедура периодической проверки целостности журналов, гарантирующая невозможность их подмены или удаления злоумышленниками. # Требования к защите

1.10. Управление доступом и аутентификация

Должно быть обеспечено строгое разграничение доступа к информационным ресурсам, соответствующее принципу минимальных привилегий. Необходимо внедрить систему аутентификации, требующую использования двух или более факторов (2FA) при входе в критически важные информационные системы. Обязуется обеспечить учет и контроль всех учетных записей, включая своевременное блокирование неактивных учетных записей в соответствии с требованиями [152-ФЗ, ст. 19].

Требуется организовать процедуру периодического пересмотра прав доступа пользователей, особенно в отношении сотрудников, чьи должностные обязанности претерпели изменения. Политика определяет, что доступ к персональным данным пациентов (ПДн) предоставляется исключительно сотрудникам, непосредственно участвующим в оказании медицинской помощи, и только в объеме, необходимом для выполнения их прямых функций. Запрещается предоставление учетных записей с правами администратора сотрудникам, не прошедшим соответствующим

ющее обучение и аттестацию.

1.11. Шифрование и защита данных

Обязательным является применение криптографических средств защиты при передаче ПДн и другой конфиденциальной информации. В частности, при обмене данными между филиалами или с внешними медицинскими учреждениями должен использоваться защищенный канал связи, например, с применением протокола TLS 1.2 или выше.

Необходимо обеспечить шифрование персональных данных и медицинских записей при их хранении в информационных системах. В соответствии с требованиями ФСТЭК России, данные, содержащие ПДн, должны храниться в защищенном контуре, защищенном от несанкционированного доступа. При работе с носителями информации, содержащими ПДн, требуется применение физических и логических средств защиты, включая шифрование на уровне диска.

1.12. Сетевая безопасность и сегментация

Требуется организовать сегментацию корпоративной сети с целью минимизации рисков распространения угроз. Должно быть обеспечено разделение сети, обслуживающей медицинские информационные системы, от общедоступных сегментов и служебных сетей.

Необходимо внедрить межсетевые экраны (Firewall) с функцией глубокой инспекции пакетов, которые осуществляют постоянный мониторинг сетевого трафика. Осуществляется мониторинг всех сетевых потоков на предмет аномальной активности, потенциально указывающей на попытку несанкционированного доступа или утечку данных. Запрещается использование незащищенных протоколов передачи данных в пределах внутренней сети организации.

1.13. Журналирование событий и мониторинг

Является обязательным ведение детализированного журнала событий (логов) всех критически важных информационных систем. Производится сбор и централизованное хранение логов аутентификации, изменения прав доступа, попыток доступа к конфиденциальным данным и всех действий, совершенных учетными записями.

Необходимо внедрить систему SIEM (Security Information and Event Management) для агрегации, анализа и корреляции данных, полученных из различных источников. Выполняется анализ журналов событий в режиме реального времени с целью оперативного выявления инцидентов информационной безопасности.

1.14. Организационные и физические меры

Организация обеспечивает регулярное обучение всего персонала работе с ПДн и требованиям информационной безопасности. Подлежит выполнению процедура проведения оценки угроз и разработка мер по их снижению в соответствии с требованиями [ФСТЭК №21, п. 15].

Требуется разработка и актуализация плана реагирования на инциденты информационной безопасности. В случае обнаружения инцидента, должно быть обеспечено немедленное оповещение ответственных лиц и выполнение регламентированных действий по локализации и устранению последствий.

Кроме того, обязательным является обеспечение физической защиты серверных помещений и рабочих мест, включая контроль доступа, видеонаблюдение и контроль климатических параметров. Должно быть обеспечено резервное копирование всех критически важных данных с соблюдением регламента хранения и периодичности восстановления. # Управление доступом

1.15. Аутентификация пользователей

Должно быть обеспечено строгое подтверждение личности каждого пользователя, осуществляющего доступ к информационным ресурсам, содержащим ПДн. В соответствии с требованиями законодательства и нормативных актов, необходимо внедрить многофакторную аутентификацию (MFA) для всех привилегированных учетных записей, а также для доступа к критически важным медицинским информационным системам.

Организация обеспечивает использование уникальных идентификаторов и паролей, которые должны соответствовать установленным политикам сложности, включая обязательное использование символов, цифр и заглавных/строчных букв. Запрещается использование общих или служебных учетных записей для выполнения рабочих задач, поскольку это затрудняет идентификацию субъекта действий. При этом, в случае временной невозможности использования основного метода аутентификации, требуется организовать процедуру подтверждения личности через альтернативные, но не менее защищенные каналы связи.

1.16. Авторизация и принцип минимальных привилегий

Политика определяет, что доступ к информационным ресурсам должен осуществляться исключительно на основании принципа минимальных привилегий. Это означает, что пользователю предоставляются только те права доступа, которые абсолютно необходимы для выполнения его должностных обязанностей, и ни одним больше.

Необходимо внедрить систему управления доступом, основанную на ролях (Role-Based Access Control, RBAC). Данная система предусматривает создание предопределенных ролей, которые группируют набор прав доступа, тем самым минимизируя риск предоставления избыточных полномочий. С учетом требований [152-ФЗ, ст. 19], доступ к персональным данным должен быть строго ограничен и контролироваться на уровне программного обеспечения.

Процедура предусматривает обязательное назначение владельца данных для каждой категории ПДн, который несет ответственность за актуальность и корректность прав доступа, присвоенных этим данным.

1.17. Технические меры контроля доступа

Требуется организовать централизованный механизм управления доступом, который обеспечивает единую точку контроля и учета всех действий пользователей. Системы должны автоматически отслеживать и фиксировать попытки несанкционированного доступа, а также успешные и неудачные попытки входа.

Обязуется обеспечить установку механизмов блокировки учетных записей после заданного количества неудачных попыток аутентификации. Кроме того, должно быть обеспечено автоматическое завершение сеанса пользователя после периода простоя, что является критически важным техническим требованием.

В частности, при работе с медицинскими информационными системами, необходимо реализовать механизм, ограничивающий доступ к определенным разделам или функциям в зависимости от профиля пользователя, что соответствует требованиям [ФСТЭК №21, п. 15].

1.18. Журналирование и управление учетными записями

Осуществляется непрерывный мониторинг всех событий доступа к ПДн. Все действия пользователей, включая просмотр, изменение или удаление данных, подлежат обязательному журналированию. Журнальные записи должны содержать не только информацию о факте доступа, но и идентификатор пользователя, время события, тип выполненной операции и объект, к которому был применен доступ.

Является обязательным регулярное выполнение процедуры пересмотра прав доступа (аттестация прав). Производится проверка актуальности должностных обязанностей и, соответственно, пересмотр списка прав доступа сотрудника не

реже одного раза в полгода.

При увольнении или изменении должностных обязанностей сотрудника, подлежит немедленному выполнению процедура аннулирования всех прав доступа и блокирования учетных записей в течение рабочего дня. С учетом требований [152-ФЗ, ст. 19], такие меры предотвращают утечку информации и минимизируют риски несанкционированного использования данных. # Ответственность

1.19. Персонал и доступ к информации

Политика определяет, что каждый сотрудник, имеющий доступ к персональным данным пациентов и медицинской информации, обязан пройти обязательный инструктаж по вопросам информационной безопасности. Необходимо внедрить систему контроля доступа, которая ограничивает доступ к информационным ресурсам исключительно по принципу минимально необходимых полномочий. Должно быть обеспечено ведение актуального реестра пользователей, в который вносятся сведения о назначении, объеме и сроках доступа к защищаемой информации.

Обязуется обеспечить подразделение, ответственное за ИБ, регулярную проверку учетных записей, неактивных или избыточных, с целью предотвращения несанкционированного использования. Запрещается передавать персональные данные третьим лицам без получения соответствующего письменного согласия субъекта данных, что является прямым нарушением требований [152-ФЗ, ст. 19]. Требуется организовать процедуру выхода сотрудника, предусматривающую немедленное аннулирование всех видов доступа к информационным системам в день прекращения трудовых отношений.

1.20. Обращение с персональными данными

Организация обеспечивает разработку и соблюдение регламентов обработки персональных данных, включая процедуры их обезличивания и минимизации.

В соответствии с требованиями [152-ФЗ, ст. 19], при работе с ПДн должно быть обеспечено их хранение на территории Российской Федерации. Является обязательным использование защищенных каналов связи (VPN, TLS) при передаче данных между филиалами или внешними контрагентами.

Необходимо внедрить систему классификации данных, которая определяет уровень защищенности для каждой категории информации. При обработке медицинских данных, в частности, должно быть обеспечено соблюдение требований, изложенных в Приказе Минздрава №956н, что включает строгий контроль за порядком сбора, хранения и передачи информации. Осуществляется мониторинг соблюдения правил работы с ПДн всеми сотрудниками, что является ключевым элементом минимизации рисков утечки.

1.21. Технические и операционные меры защиты

Требуется организовать комплекс технических мер защиты, включающий межсетевые экраны, системы обнаружения вторжений (IDS) и системы управления событиями безопасности (SIEM). Должно быть обеспечено регулярное резервное копирование всех критически важных информационных систем с последующей проверкой возможности восстановления данных. Производится проверка работоспособности средств защиты информации не реже одного раза в квартал.

Обязуется обеспечить шифрование персональных данных как при их хранении (at rest), так и при передаче (in transit), используя криптографические алгоритмы, соответствующие требованиям ФСТЭК России. В частности, при работе с медицинскими записями должно применяться шифрование с использованием ключей, управляемых в соответствии с требованиями [ФСТЭК №21, п. 15]. Выполняется анализ журналов событий безопасности (логирование) с целью выявления подозрительной активности и своевременного реагирования на инциденты.

1.22. Реагирование на инциденты

Политика определяет четкий алгоритм действий при возникновении инцидента информационной безопасности. Необходимо внедрить команду реагирования на инциденты, которая должна быть готова к круглосуточному дежурству. Осуществляется мониторинг систем на предмет аномалий, что позволяет своевременно локализовать угрозу.

В случае обнаружения нарушения режима защиты информации, должно быть немедленно инициировано оповещение ответственных лиц. Обязуется обеспечить документирование всех этапов реагирования на инцидент, включая причины, последствия и предпринятые корректирующие меры. Производится регулярное обучение персонала навыкам действий в условиях кризисной ситуации, что является неотъемлемой частью поддержания высокого уровня информационной безопасности. # Контроль и аудит

1.23. Техническое журналирование событий

Должно быть обеспечено ведение непрерывного и детализированного журналирования всех критически важных событий в информационных системах. Производится сбор и централизованное хранение журналов доступа, изменений конфигурации, попыток несанкционированного доступа, а также всех операций с персональными данными. В частности, обязательным является протоколирование действий, связанных с доступом к медицинским информационным системам (МИС) и обработкой персональных данных пациентов.

Необходимо внедрить систему SIEM (Security Information and Event Management) которая обеспечивает агрегацию данных из различных источников, позволяя оперативно выявлять аномалии и подозрительную активность. Обязуется обеспечить защиту журналов от несанкционированного изменения или удаления, что является требованием, изложенным в соответствии с требованиями ФСТЭК России. С учетом требований [152-ФЗ, ст. 19], журналирование должно фиксировать не

только факт доступа, но и идентификационные данные субъекта, а также время и причину запроса информации.

1.24. Мониторинг и обнаружение инцидентов

Осуществляется постоянный мониторинг функционирования защищенных информационных систем. Требуется организовать круглосуточный мониторинг сетевого трафика и активности пользователей, что позволяет своевременно обнаруживать признаки кибератак, утечек или нарушения режима конфиденциальности. Система мониторинга должна быть настроена на оповещение ответственных лиц при выявлении критических отклонений от нормального режима работы.

В соответствии с требованиями [ФСТЭК №21, п. 15], должно быть разработано и утверждено Положение об обработке и реагировании на инциденты информационной безопасности. Данное положение определяет четкую последовательность действий при обнаружении инцидента, включая процедуры локализации ущерба, уведомления руководства и взаимодействия с контролирующими органами. Обязательно проведение регулярных учений и тренировок персонала, имитирующих реальные инциденты, для отработки навыков реагирования.

1.25. Периодический аудит и тестирование

Является обязательным проведение регулярных внутренних и внешних аудитов системы информационной безопасности. Аудит должен охватывать все аспекты обработки персональных данных, включая физические средства хранения, программное обеспечение и организационные процессы. В рамках аудита проводится проверка соответствия фактического состояния ИС установленным политикам и требованиям законодательства, в частности, [152-ФЗ, ст. 19].

Необходимо проводить периодическое тестирование на проникновение (пентестинг) защищенных информационных систем. Данные мероприятия направлены на выявление уязвимостей в программном и аппаратном обеспечении, которые

могут быть использованы злоумышленниками. Результаты тестирования подлежат обязательному рассмотрению и устранению выявленных недостатков в установленные сроки.

1.26. Отчетность и документация

Производится систематизация и хранение всей документации, связанной с мероприятиями по обеспечению ИБ, включая протоколы аудитов, отчеты об инцидентах, результаты тестирования и акты устранения уязвимостей. Ответственные подразделения обязаны формировать отчетность для руководства и контролирующих органов.

В соответствии с требованиями [Минздрав №956н], должна быть обеспечена документальная фиксация всех процедур, связанных с обработкой медицинских данных. Обязуется ежеквартально формировать отчет о состоянии защищенности персональных данных, который должен содержать анализ рисков, принятых мер по их минимизации и план дальнейших улучшений. Подлежит выполнению требование о предоставлении отчетов о соблюдении режима защиты информации в установленные сроки. # Заключительные положения

1.27. Область применения и ответственность

Политика определяет требования к защите персональных данных пациентов и сотрудников БУЗОО «МИАЦ» при обработке информации в информационных системах. Является обязательным к исполнению для всех структурных подразделений, сотрудников, а также сторонних исполнителей, осуществляющих обработку персональных данных в рамках оказания медицинской помощи.

Обязуется обеспечить соблюдение требований данной Политики все лица, имеющие доступ к информационным системам и обрабатывающие персональные данные. В частности, должно быть обеспечено ознакомление каждого сотрудника с актуальными редакциями Политики и сопутствующих локальных норматив-

ных актов. Недопущение соблюдения установленных процедур, включая передачу конфиденциальной информации третьим лицам без соответствующего согласия, влечет за собой дисциплинарную, административную и уголовную ответственность в соответствии с действующим законодательством Российской Федерации, включая [152-ФЗ, ст. 19].

1.28. Регламент пересмотра и актуализации

Политика подлежит обязательному периодическому пересмотру и актуализации. Производится проверка документации не реже одного раза в год, а также в случае существенных изменений в законодательстве Российской Федерации, в частности, при изменении требований, установленных [ФСТЭК России №21, п. 15], или при внедрении новых информационных систем.

Требуется организовать процесс фиксации всех изменений, внесенных в Политику. В рамках этого процесса осуществляется анализ технологических рисков, связанных с обработкой медицинских данных. Должно быть обеспечено, что все технические и организационные меры, описанные в документе, соответствуют текущему уровню угроз и требованиям безопасности.

1.29. Технические и организационные меры

Необходимо внедрить систему контроля доступа, предусматривающую принцип минимально необходимых привилегий. Доступ к персональным данным должен предоставляться только по служебной необходимости и строго документироваться.

Осуществляется мониторинг всех критически важных информационных ресурсов с целью выявления несанкционированного доступа или попыток компрометации. В соответствии с требованиями [ФСТЭК №21, п. 15], должно быть обеспечено централизованное журналирование всех событий безопасности, включая попытки входа и изменение настроек систем.

Также требуется организовать регулярное проведение аудита информационной безопасности. Производится проверка настроек межсетевых экранов, систем обнаружения вторжений и механизмов шифрования. В частности, при передаче персональных данных через внешние сети обязательно использование защищенных каналов связи, например, с применением протоколов TLS или VPN.

1.30. Управление инцидентами

В случае обнаружения инцидента информационной безопасности, сотруднику предписывается немедленно уведомить ответственное подразделение. Обязуется обеспечить выполнение процедуры реагирования на инциденты, которая включает локализацию угрозы, сбор доказательной базы и составление отчета о произошедшем событии.

Система управления инцидентами должна предусматривать четкий алгоритм действий, минимизирующий ущерб и обеспечивающий своевременное восстановление работоспособности информационных систем. Все инциденты, независимо от их масштаба, подлежат документированию и последующему анализу для предотвращения повторения подобных происшествий.

1.31. Контроль исполнения

Контроль за соблюдением требований данной Политики возлагается на ответственное подразделение по информационной безопасности. Периодически проводится проверка готовности сотрудников к выполнению своих обязанностей в условиях угрозы.

Подлежит выполнению регулярное обучение персонала по вопросам информационной безопасности. В рамках обучения должны освещаться требования [Минздрав №956н] и правила работы с медицинской информацией. Несоблюдение требований Политики, выявленное в ходе проверок, влечет за собой применение мер дисциплинарного взыскания в соответствии с внутренними норматив-

ными актами БУЗОО «МИАЦ».

Нормативные ссылки

- Федеральный закон №152-ФЗ от 27.07.2006 «О персональных данных»
- Приказ ФСТЭК России №21 от 18.02.2013 «Об утверждении Состав и содержания организационных и технических мер по обеспечению безопасности персональных данных»
- Приказ Минздрава России №956н от 15.12.2020 «Требования к защите ПДн в сфере здравоохранения»